



IT and Telecom Sector Frauds and Countermeasures



UNIVERSITY OF MADRAS
INSTITUTE OF DISTANCE EDUCATION

சென்னைப் பல்கலைக்கழகம்
தொலைதூரக் கல்வி நிறுவனம்

E.R. Ramesh, M.C.A., M.Sc., M.B.A.,

Frauds in IT, Software Development and Management

IT Frauds

- Theft of Proprietary information
- Insider abuse of internet access
- System penetration
- Unauthorized access to information
- Laptop/Mobile Theft, Financial Fraud
- Misuse of public web application
- Virus, Abuse of wireless network –
- Countermeasures

- Frauds in Software development and Management
- Software Industry Frauds - Countermeasures



Basics

Fraud

*A **false representation** of a matter of fact—either by words or by conduct, by false or misleading allegations, or by **concealment** of what should have been disclosed—that deceives and is intended to deceive another so that the individual will act upon it to her or his legal injury.*



Fraud is commonly understood as **dishonesty calculated for advantage**. A person who is dishonest may be called a **fraud**.

Discuss: Error (typo error or careless), Mistake (unintentional), etc.

Basics

Fraud is a deception deliberately practiced in order to secure unfair or unlawful gain.

As a legal construct, fraud is both

➤ **a civil wrong**

- (i.e., a fraud victim may sue the fraud perpetrator to avoid the fraud and/or recover monetary compensation)

➤ **and a criminal wrong**

- (i.e., a fraud perpetrator may be prosecuted and imprisoned by governmental authorities).

Basics

Usual purpose of fraud is to get **monetary benefits** and sometimes for obtaining **other benefits** – e.g., obtaining a driver's license by way of false statements made in an application for the same.

Discuss – Forgery, falsifying, tampering, manipulating, counterfeit, etc.



Cognizable vs Non-Cognizable

- All serious offences are considered as Cognizable.
- The seriousness of the offence depend upon the maximum punishment provided for the offence. By and large, offences punishable with imprisonment for not less than 3 years are taken as serious offences and are made cognizable.
- If it is cognizable offence, a police officer can arrest without warrant for such an offence.
- **E.g., Murder, Robbery, Theft, Rioting, Counterfeiting, etc.**

Cognizable vs Non-Cognizable

- Offences which are not serious and are punishable with less than 3 years imprisonment are treated as non-cognizable offences.
- **E.g., Public Nuisance, Causing Simple Hurt, Assault, Mischief, etc.**

Basics

Forgery

- The process of making, adapting, or imitating objects, statistics, or documents with the intent to deceive or make usually large amounts of money by selling the forged item.
- Copies, studio replicas, and reproductions are not considered forgeries, though they may later become forgeries through knowing and willful misrepresentations.
- When the object forged is a record or document it is often called a false document.

Discuss – Photocopy of documents

Discuss

Information Security vs. IT Security

Are they same? Or differ?

What needs to be protected from Fraudsters?

- **IT Hardware**
 - Servers
 - Devices
 - Network
- **Software**
 - Operating system
 - Middleware system
 - Database
 - Applications

Infrastructure Asset



Information Asset

Fraud

- A **Fraud** is an intentional act performed to gain either monetary or other types of benefit.

The Fraud Triangle



Motive (or) Pressure

MOTIVE is the element that compels an individual to resort to fraud to accomplish their goals or meet their needs:

- Unobtainable management-imposed budget, cash flow pressures, investor expectations
- Maturing loan or restrictive loan covenants
- Substance abuse, excessive debt, or living beyond one's mean
- Medical emergencies

Opportunity

OPPORTUNITY relates to access to assets or the ability within an organization to manipulate

- financial documents or records to cause financial statements to be misrepresented and to cover up any wrong-doings.
- Management should attempt to minimize opportunity by establishing various accounting and administrative controls.

Rationalization

RATIONALIZATION is the thought process that a person goes through to convince

- themselves that what they have done is acceptable. Typical rationalizations include:
 - “It was for the good of the company”
 - “I was just borrowing the money”
 - “I didn’t get the raise I deserved, so I was only taking what was mine”
- Often is an attempt to depersonalize their actions:
 - “I wasn’t stealing from my boss, I was stealing from the organization”
 - “The only one to get hurt was the bank, and they can afford it”

Fraud Ring

- An organization whose activities are aimed to defraud people. A fraud ring may be engaged in forgery, filing false claims, identity stealing or counterfeiting cheques and currencies.

Discuss:

**Tamil Movie – Thegidi - Hero - Detective agent – victims
– insurance policy – murder – claim.**

IT Law - India

- Information Technology Act, 2000
- Amendment in 2008
- Primary law in India dealing with Cybercrime and Electronic commerce.
- In most of the cases, sections from IPC are borrowed.

IT Act, 2000 (Amended 2008)

Section	Offence
65	Tampering with computer source documents
66	Hacking with computer system
66B	Receiving stolen computer or communication device
66C	Using password of another person
66D	Cheating using computer resources
66E	Publishing private images of others
66F	Acts of cyberterrorism
67	Publishing information which is obscene in electronic form.
67A	Publishing images containing sexual acts
67B	Publishing child porn or predating children online
67C	Failure to maintain records
68	Failure/refusal to comply with orders
69	Failure/refusal to decrypt data
70	Securing access or attempting to secure access to a protected system
71	Misrepresentation

Basic Terminologies

Tangible asset vs. Intangible asset



Basic Terminologies

Safety *vs.* Security

Data *vs.* Information

Preventive *vs.* Detective controls

Proprietary Information

Software piracy

The unauthorized copying of software. Most retail programs are licensed for use at just one computer site or for use by only one user at any time.



Proprietary Information

Software piracy

By buying the software, you become a *licensed user* rather than an owner. You are allowed to make copies of the program for backup purposes, but it is against the law to give copies to friends and colleagues.

e.g., Counterfeit software, OEM unbundling, Softlifting, Hard disk loading, Corporate software piracy, Internet software piracy, etc.

Software Piracy

Counterfeit software

A type of software piracy that occurs when fake copies of software are produced in such a way that they appear to be authentic.

Counterfeit software would include the illegal copying and distribution of commercial software on CD or DVD along with any accompanying manuals that the original legitimate software was sold with.

Software Piracy

Counterfeit software

Counterfeit software is commonly produced using a CD burner to copy the software and photocopies are made of the manual.

Counterfeit software is usually sold at prices well below that of the retail price of the legitimate software.

Software Piracy

OEM Unbundling

Often called OEM piracy or just unbundling, OEM unbundling is a type of software piracy that occurs when OEM-packaged software is separated from the hardware it originally came bundled with, at the OEM or retail level of sale.

The software is clearly marked, usually with the phrase "For Distribution with New PC Hardware Only", and the act of piracy occurs when the software is installed on another computer system.

Software Piracy

OEM Unbundling

OEM - OEM is short for original equipment manufacturer, which is a misleading term for a company that has a special relationship with computer producers.

OEMs are manufacturers who resell another company's product under their own name and branding.

Software Piracy

OEM Unbundling

While an OEM is similar to a VAR (value-added reseller), it refers specifically to the act of a company rebranding a product to its own name and offering its own warranty, support and licensing of the product.

The term is really a misnomer because OEMs are not the original manufacturers; they are the customizers.

Software Piracy

Softlifting

A type of software piracy that occurs when users share their software with other users who are not authorized to have access by the End-User License Agreement (EULA).

The most common type of softlifting occurs when a person does legitimately purchase software but installs it onto multiple computers which is a violation of the licensing agreement. Softlifting may also be called softloading or end-user piracy.

Software Piracy

Hard disk loading

A type of software piracy that occurs when hardware dealers; brick-and-mortar or Internet vendors, install an unauthorized copy of commercial software onto a computer system.

In many cases consumers will not receive any manuals or original CD of the software but the hardware dealer may charge for the illegal software in the total system purchase price.

Software Piracy

Hard disk loading

The end-user, or the purchaser in this case, will then use the computer system with pirated software, often not realizing that the software that was pre-installed on the computer system is not legitimate.

This type of piracy is most common with operating systems, especially older Microsoft branded operating systems such as Windows operating systems.

Software Piracy

Hard disk loading

Public awareness along with requiring users to activate or register their products has helped software manufactures deal with hard disk loading piracy.

Software Piracy

Corporate software piracy

A type of software piracy that occurs when corporations underreport the number of software installations acquired through volume purchase agreements.

Corporate software policy may also be an offence when software is installed on a server with unrestricted staff access.

May also be called corporate end-user piracy.

Software Piracy

Internet software piracy

A type of software piracy that occurs when software, which is illegally obtained through Internet channels, usually through peer-to-peer file sharing systems or downloaded from pirate Web sites that make software available for download for free or in exchange for users who uploaded software.

Software Piracy

Internet software piracy

Internet software piracy also includes the sale of counterfeit software on Internet auction and classified ads Web sites.

Counterfeit software with de-activate the copy-protection that can be obtained through Internet channels is called warez.

Software Piracy

Warez

Commercial software that has been pirated and made available to the public via a BBS or the Internet. Typically, the pirate has figured out a way to de-activate the copy-protection or registration scheme used by the software.

Note that the use and distribution of warez software is illegal.

In contrast, shareware and freeware may be freely copied and distributed.

Discuss: Shareware, freeware.

Software Piracy

BBS – Bulletin Board System

An electronic message center. Most bulletin boards serve specific interest groups.

They allow you to dial in with a modem, review messages left by others, and leave your own message if you want.

Bulletin boards are a particularly good place to find free or inexpensive software products.

Copyright Infringement

Copyright infringement

Copyright infringement is the use of works protected by copyright law without permission, infringing certain exclusive rights granted to the copyright holder, such as the right to reproduce, distribute, display or perform the protected work, or to make derivative works.

The copyright holder is typically the work's creator, or a publisher or other business to whom copyright has been assigned.

Copyright Infringement

Copyright infringement

Work - a work must meet minimal standards of originality in order to qualify for copyright, and the copyright expires after a set period of time (some jurisdictions may allow this to be extended).

Different countries impose different tests, although generally the requirements are low; in the United Kingdom there has to be some 'skill, labour, and judgment' that has gone into it.

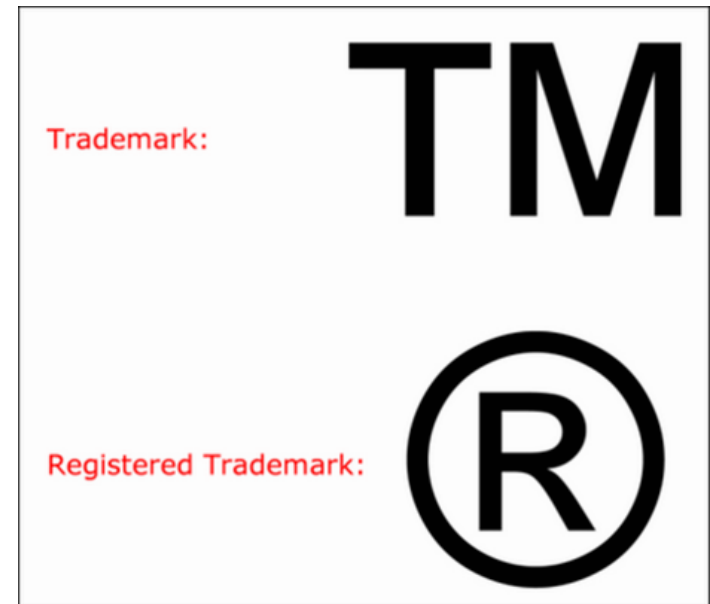


Trademark violations

Trademarks violations

Trade mark is a recognizable sign, design or expression which identifies products or services of a particular source from those of others. The trademark owner can be an individual, business organization, or any legal entity.

A trademark may be located on a package, a label, a voucher or on the product itself. For the sake of corporate identity trademarks are also being displayed on company buildings.



Software code

Theft of software code

Employee – Copying illegally from the system; where it was written/developed.

Discuss:

- Software programmer copying the codes from his official system and he/she is the original writer of the software code.
 - Who holds the Copyright – Software programmer ?
Or
 - His/Her employer?

Copyright Infringement

Copyright in a work shall be deemed to be infringed- (a) when any person, without a licence granted by the owner of the copyright or the Registrar of Copyrights under this Act or in contravention of the conditions of a licence so granted or of any condition imposed by a competent authority under this Act-

(i) does anything, the exclusive right to do which is by this Act conferred upon the owner of the copyright; or

Copyright Infringement

- (i) permits for profit any place to be used for the communication of the work to the public where such communication constitutes an infringement of the copyright in the work, unless he was not aware and had no reasonable ground for believing that such communication to the public would be an infringement of copyright; or
- (b) when any person-
 - (i) makes for sale or hire, or sells or lets for hire, or by way of trade displays or offers for sale or hire, or

Copyright Infringement

- (i) distributes either for the purpose of trade or to such an extent as to affect prejudicially the owner of the copyright, or
- (ii) by way of trade exhibits in public, or
- (iii) imports 22[* * *] into India, any infringing copies of the work:
PROVIDED that nothing in sub-clause (iv) shall apply to the import of one copy of any work for the private and domestic use of the importer.

The reproduction of a literary, dramatic, musical or artistic work in the form of a cinematograph film shall be deemed to be an "infringing copy".

Discuss

Reported/Published frauds in IT

Intellectual Property Crimes

Illustration 1

Bharti Cellular Ltd. filed a case in the Delhi High Court that some cyber squatters had registered domain names such as `barticellular.com` and `bhartimobile.com` with Network solutions under different fictitious names.

The court directed Network Solutions not to transfer the domain names in question to any third party and the matter is sub-judice.

Intellectual Property Crimes

Illustration 2

Yahoo had sued one Akash Arora for use of the domain name 'Yahooindia.Com' deceptively similar to its 'Yahoo.com'.

As this case was governed by the Trade Marks Act, 1958, the additional defence taken against Yahoo's legal action for the interim order was that the Trade Marks Act was applicable only to goods.

Intellectual Property Crimes

Illustration 3

A software professional from Bangalore (India) was booked for stealing the source code of a product being developed by his employers.

He started his own company and allegedly used the stolen source code to launch a new software product.

Intellectual Property Crimes

Illustration 4

In 2003, a computer user in China obtained the source code of a popular game - Lineage from an unprotected website. This proprietary code was then sold to several people in 2004.

One of those people set up a website, www.l2extreme.com, to offer the "Lineage" game at a discount.

Intellectual Property Crimes

Illustration 4

Despite legal warnings from the South Korean company that owned the Lineage source code, the suspect did not shut down the site. He rented powerful servers enough to accommodate 4,000 simultaneous gamers - and solicited donations from users to help defray the costs.

The loss in potential revenues for the South Korean company was estimated at \$750,000 a month. The US FBI arrested the suspect and the website was shut down.

For Piracy - Sec. 51, 63, 63 B Copyright Act will be applicable.

Who is an insider?

Insider

- An insider is the legitimate system user who is granted and can use certain privileges.
- Intuitively, insider threats involve such users misusing those privileges, potentially causing violations of confidentiality, data integrity, system integrity, system survivability, identity management, accountability, denials of service, and anything else relating to abuse of trust.

Who is an insider?



**Discuss: Competitors, Disgruntled employees,
HR – Personality - Programs/Sessions**

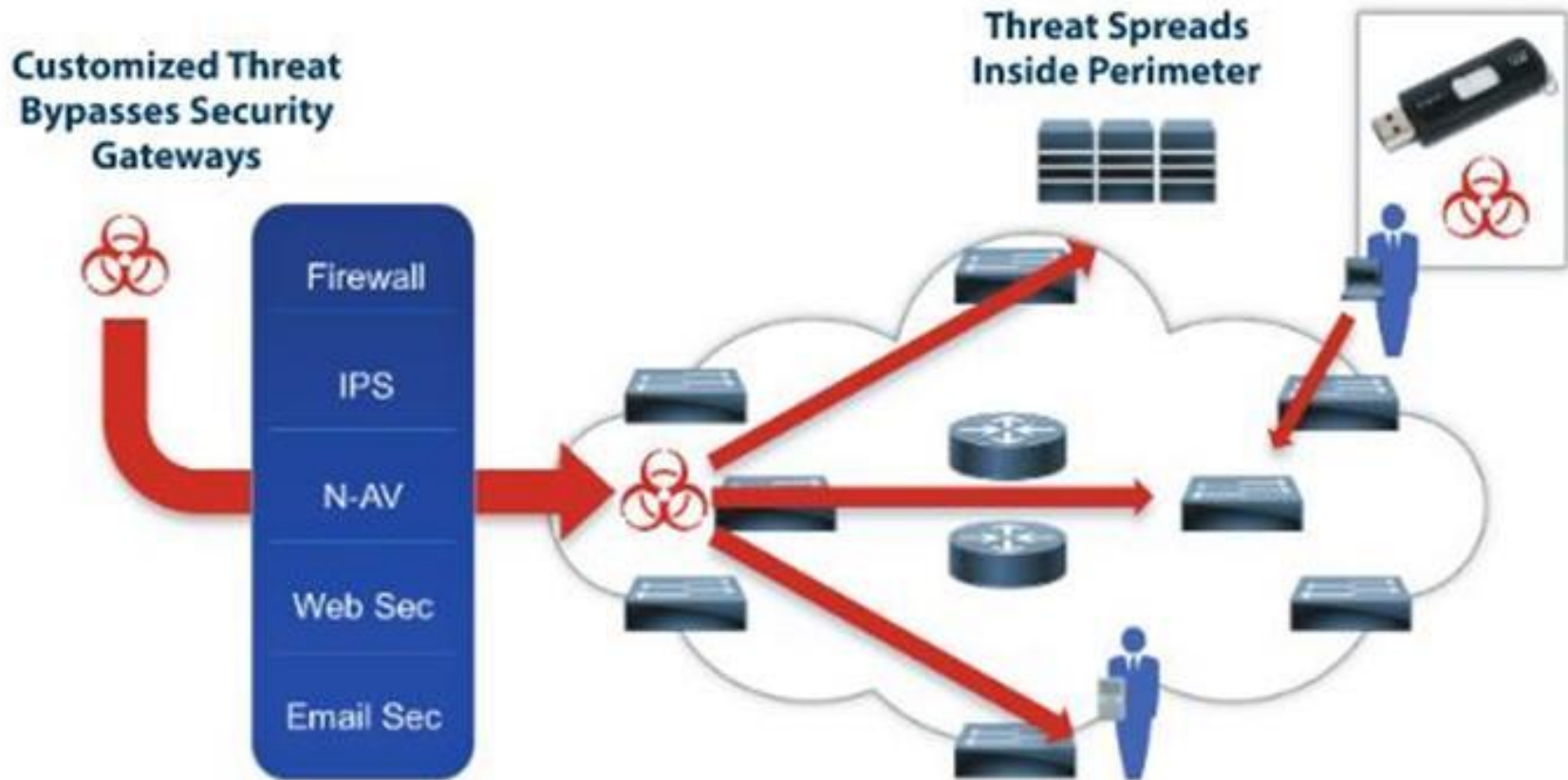
Insider threats

No need:

- to penetrate system boundary systems (i.e., to break the first line of defense)
- to use sophisticated tools to get access to the resources
- to spend more time/effort to guess the network architecture (because an insider will have good knowledge of their own network and protocols in use)

Discuss: Firewall, Anonymous/guest logon,
SSO (single sign-on)

Insider threats – Inside Perimeter



Types of insider threats

1. Intentional
2. Accidental misuse

Challenges:

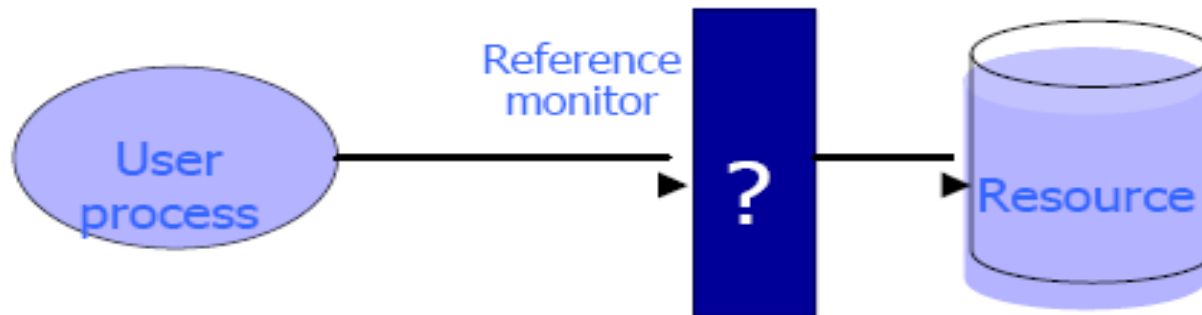
- System and network DoS are likely to be **overt**, can be detected at early stage, whereas insertion of stealthy Trojan horses that act as sniffers or that quietly leak information are typically intended to be **covert**, and their desired purpose may be to remain undetected for longer periods.

Access Control

Access control

◆ Common Assumption

- System knows who the user is
 - User has entered a name and password, or other info
- Access requests pass through gatekeeper
 - Global property; OS must be designed so that this is true



Decide whether user can apply operation to resource

Insider threat – Access to sensitive documents



Insider threats

Misuse of internet

- Personal entertainment (e.g., playing games, writing personal emails, etc.)
- Downloading MP3s, pirated software, pornographic materials, or other unsuitable material
- Fraud and theft (e.g., modifying payroll database to increase one's wages)
- Sending out inappropriate material using company computers
- Installing and using pirated software
- Reading or modifying another user's files

Countermeasures

- Strong access control mechanisms to be implemented
 - ACL (Access Control Lists)
 - RBAC model
- Enforcement by Corporate policies
 - Asset Usage Policy (e.g., Internet access usage)
 - NDAs

Countermeasures

- Least privilege
 - Need-to-know
 - Need-to-do
- Continuous monitoring process
 - NOC (Network Operating Center)
 - SMC (Security Monitoring Center)
 - IDS (Signature / Anomaly based detection)
 - Event Management process
 - Audit (Internal & External)

Countermeasures

- Log suspicious activities
 - Failed logon attempts
 - Huge consumption of bandwidth
 - Usage of insecure protocols
 - Sign-in from risky IP address (e.g. tor browser)
 - Mass download by an user
 - Impossible Travel Activity
 - Mass delete by an user
 - Admin activities performed from Non-corporate IP address

System penetration

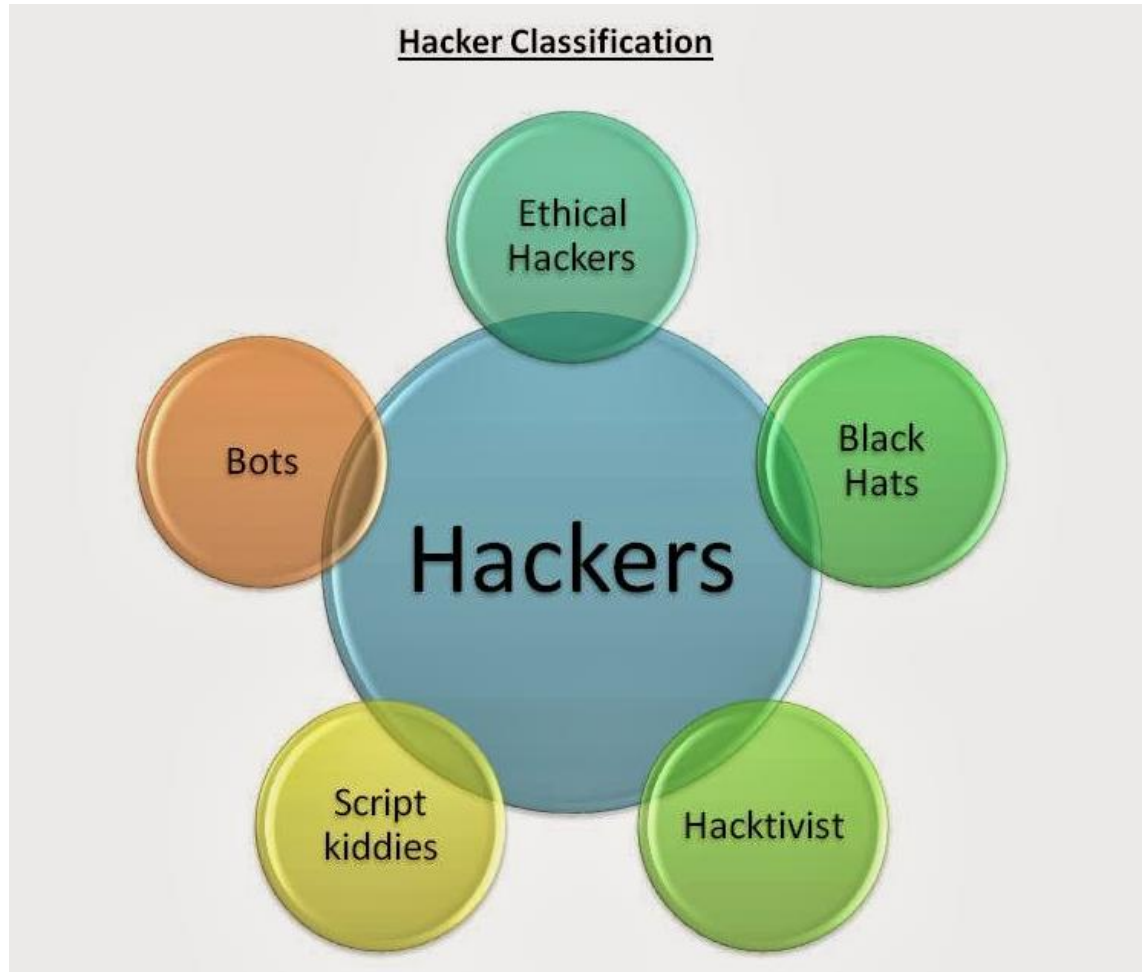
Hacking

Hacking means unauthorized attempts to bypass the security mechanisms of an information system or network. Also, in simple words Hacking is the unauthorized access to a computer system, programs, data and network resources.

Note: The term “**hacker**” originally meant a very gifted programmer. In recent years though, with easier access to multiple systems, it now has negative implications.)



Hacking



White Hat

- A white hat hacker breaks security for non-malicious reasons.
- The term "white hat" in Internet slang refers to an ethical hacker.
- Includes individuals who perform penetration tests and vulnerability assessments within a contractual agreement.



Black Hat

- A "black hat" hacker is a hacker who "violates computer security for little reason beyond maliciousness or for personal gain".
- Black hat hackers break into secure networks to destroy data or make the network unusable for those who are authorized to use the network.
- Black hat hackers also are referred to as the "crackers" within the security industry and by modern programmers.



Gray Hat

- A grey hat hacker is a combination of a black hat and a white hat hacker.
- A grey hat hacker may surf the internet and hack into a computer system for the sole purpose of notifying the administrator that their system has a security defect, for example.
- Then they may offer to correct the defect for a fee.



Elite Hacker

- A social status among hackers, elite is used to describe the most skilled.
- Newly discovered exploits will circulate among these hackers.



Script Kiddie

- A script kiddie is a non-expert who breaks into computer systems by using pre-packaged automated tools written by others, usually with little understanding of the underlying concept—hence the term script kiddie.
- (i.e. kid, child—an individual lacking knowledge and experience, immature).

System penetration

Law & Punishment:

Under Information Technology (Amendment) Act, 2008, Section 43(a) read with section 66 is applicable and Section 379 & 406 of Indian Penal Code, 1860 also are applicable.

If crime is proved under IT Act, accused shall be punished for imprisonment, which may extend to three years or with fine, which may extend to five lakh rupees or both.

Hacking offence is cognizable, bailable, compoundable with permission of the court before which the prosecution of such offence is pending and triable by any magistrate.

Unauthorized access to information

Data Theft

Primarily perpetrated by office workers with access to technology such as desktop computers and handheld devices, capable of storing digital information such as flash drives, iPods and even digital cameras.



Unauthorized access to information

Data Theft

The damage caused by data theft can be considerable with today's ability to transmit very large files via e-mail, web pages, USB device, DVD storage and other hand-held devices.



Unauthorized access to information

Law & Punishment:

According to Information technology (Amendment) Act, 2008, crime of data theft under Section 43 (b) is stated as –

If any person without permission of the owner or any other person, who is in charge of a computer, computer system of computer network - downloads, copies or extracts any data, computer data base or information from such computer, computer system or computer network including information or data held or stored in any removable storage medium, then it is data theft.

Unauthorized access to information

Law & Punishment:

Under Information Technology (Amendment) Act, 2008, Section 43(b) read with Section 66 is applicable and under Section 379, 405 & 420 of Indian Penal Code, 1860 also applicable.

Data Theft offence is cognizable, bailable, compoundable with permission of the court before which the prosecution of such offence is pending and triable by any magistrate.

Laptop/Mobile theft



Laptop/Mobile theft

Laptop theft is a significant threat to users of laptop and netbook computers.

Many methods to protect the data and to prevent theft have been developed, including alarms, laptop locks, and visual deterrents such as stickers or labels.



Laptop/Mobile theft

Laptop theft is a significant threat to users of laptop and netbook computers.

Many methods to protect the data and to prevent theft have been developed, including alarms, laptop locks, and visual deterrents such as stickers or labels.



Full Disk Encryption (FDE)

Inside protection

Passwords are no longer adequate to protect laptops. There are many solutions that can improve the strength of a laptop's protection.

Full disk encryption (FDE) is an increasingly popular and cost-effective approach. Full disk encryption can be taken on from a software-based approach, a hardware-based approach, or both - end-based approach.

FDE provides protection before the operating system starts up with pre-boot authentication, however precautions still need to be taken against cold boot attacks.

Full Disk Encryption (FDE)

- Full-disk encryption (FDE) is encryption at the hardware level. FDE works by automatically converting data on a hard drive into a form that cannot be understood by anyone who doesn't have the key to “undo” the conversion.
- Without the proper authentication key, even if the hard drive is removed and placed in another machine, the data remains inaccessible.
- FDE can be installed on a computing device at the time of manufacturing or it can be added later on by installing a special software driver.

Full Disk Encryption (FDE)

- The advantage of FDE is that it requires no special attention on the part of the end user after he initially unlocks the computer.
- As data is written, it is automatically encrypted. When it is read, it is automatically decrypted. Because everything on the hard drive is encrypted, including the operating system, a disadvantage of FDE is that the encrypting/decrypting process can slow down data access times, particularly when virtual memory is being heavily accessed.

Full Disk Encryption (FDE)

- FDE is especially useful for laptops and other small computing devices that can be physically lost or stolen.
- Because one key is used to encrypt the entire hard drive, FDE on the corporate level requires the network administrator to enforce a strong password policy and provide an encryption key backup process in case an employee forgets his password or leaves the company unexpectedly.

Remote Laptop Security (RLS)

- Passwords provide a basic security measure for files stored on a laptop, though combined with disk encryption software they can reliably protect data against unauthorized access.
- Remote Laptop Security (RLS) is available to confidently secure data even when the laptop is not in the owner's possession.
- With Remote Laptop Security, the owner of a laptop can deny access rights to the stolen laptop from any computer with Internet access.

Laptop/Mobile theft

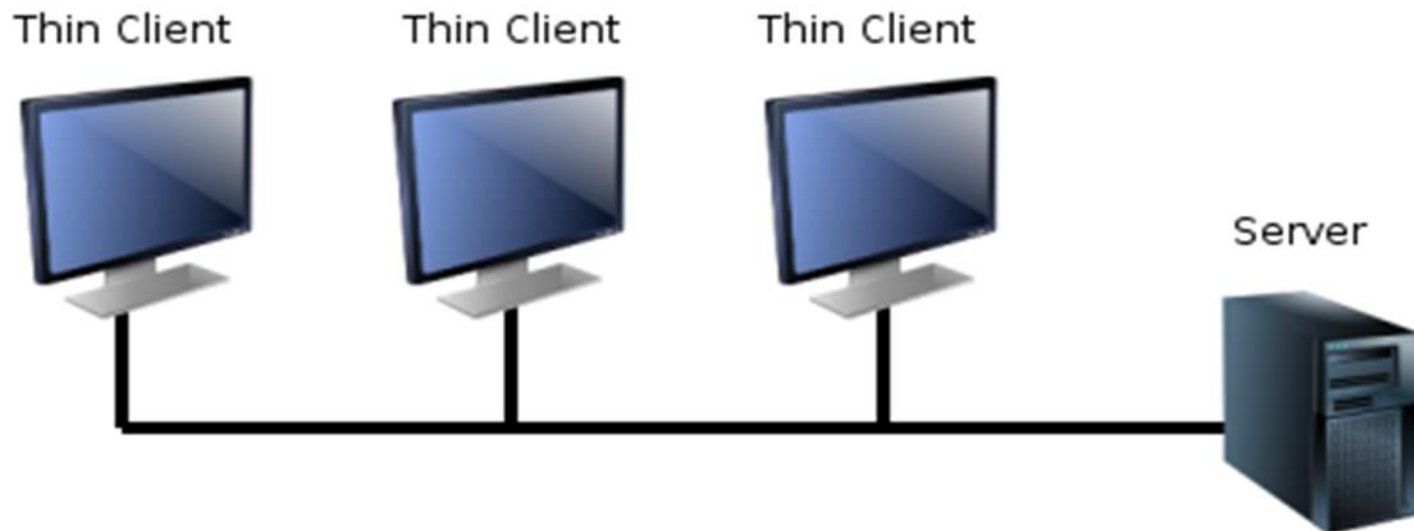
Physical protection

- The Kensington Security Slot along with a locking cable provides physical security against thefts of opportunity.
- This is a cord that is attached to something heavy that cannot be moved, and is then locked into the case of the laptop, but this is not 100% secure.



Centralization of data

- Another possible approach to limiting the consequences of laptop theft is to issue thin client devices to field employees instead of conventional laptops, so that all data will reside on the server and therefore may be less liable to loss or compromise.



Centralization of data

- Thin client depends on network access to the server, which is not available aboard airliners or any other location without network access.
- This approach can be coupled with strong authentication as such **single sign-on (SSO)**.

Most likely places where laptops are stolen

- Public Schools
- Residential Properties
- Automobiles (excluding taxis)
- Businesses/Offices
- Universities and Colleges
- Restaurants and Cafes
- Hotels and Motels
- Dormitory
- Airports
- Public Transit (taxi, bus, train)



Financial Frauds

Financial Frauds committed in business

- Drawing up financial statements of the business falsely
- Embezzlement of the money during its collection but before it is recorded in accounts
- Stealing the cheques of business
- Tampering the bank records and taking monetary advantage



Financial Frauds



Financial Frauds committed in business

- Gaining advantage through forgery of financial documents
- Making payments which should not be made or previously made
- Creating fictitious debts and having payments done in favor of oneself

Financial Frauds



Financial Frauds committed in business

- Giving discount improperly or without authority
- Creating Ghost suppliers and having payments made in their favor

Financial Frauds

Financial Frauds committed in business

- Creating fictitious expenses and obtaining disbursements
- Padding expense items
- Benefiting from placing redundant order
- Creating ghost employees and embezzling their wages/salaries



Financial Frauds

Financial Frauds committed in business

- Using credit cards of the business for personal objectives
- Manipulating the overtime periods and obtaining extra payment
- Benefiting from padded travel expenses
- Selling business assets under the market value

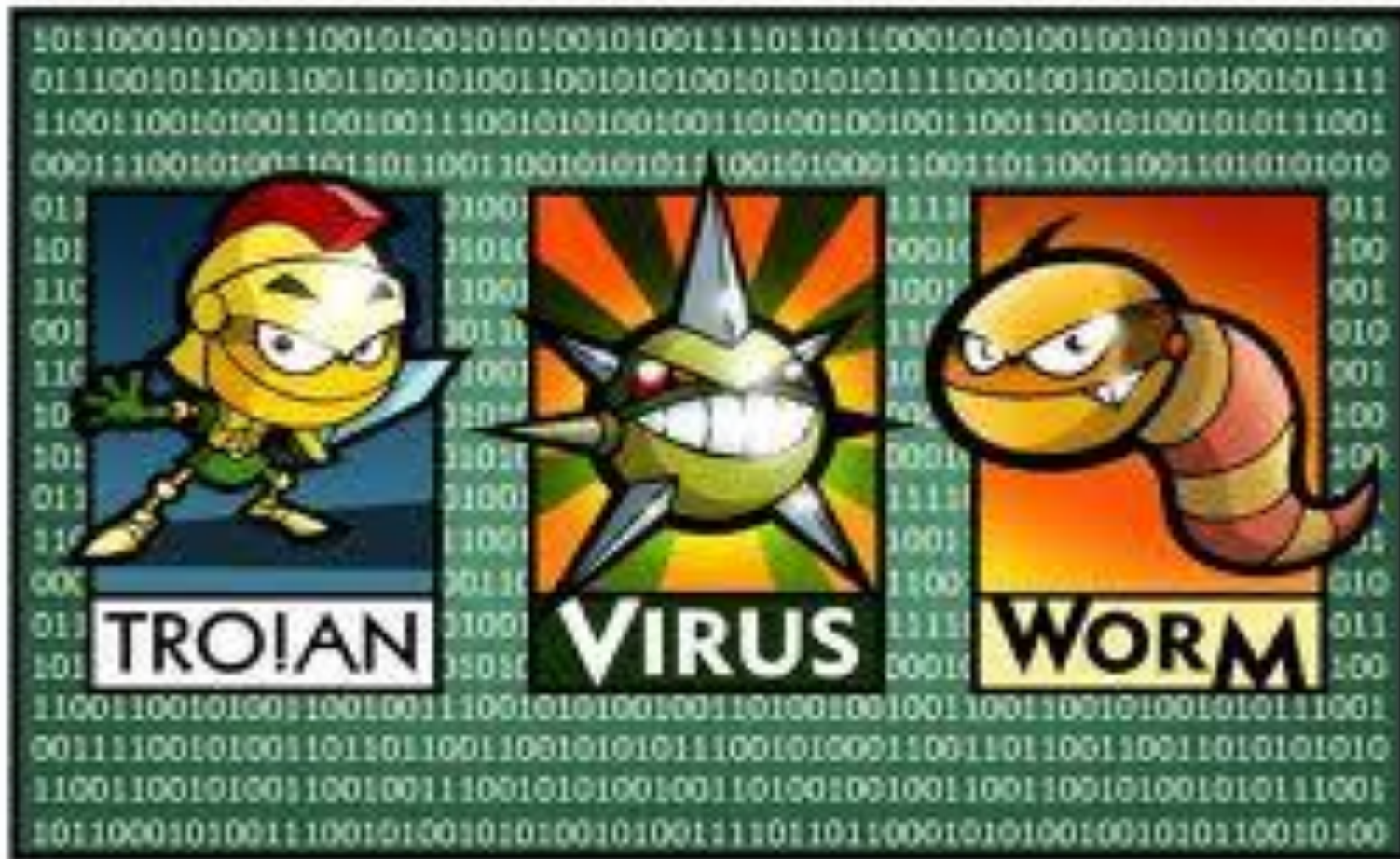


Malicious codes

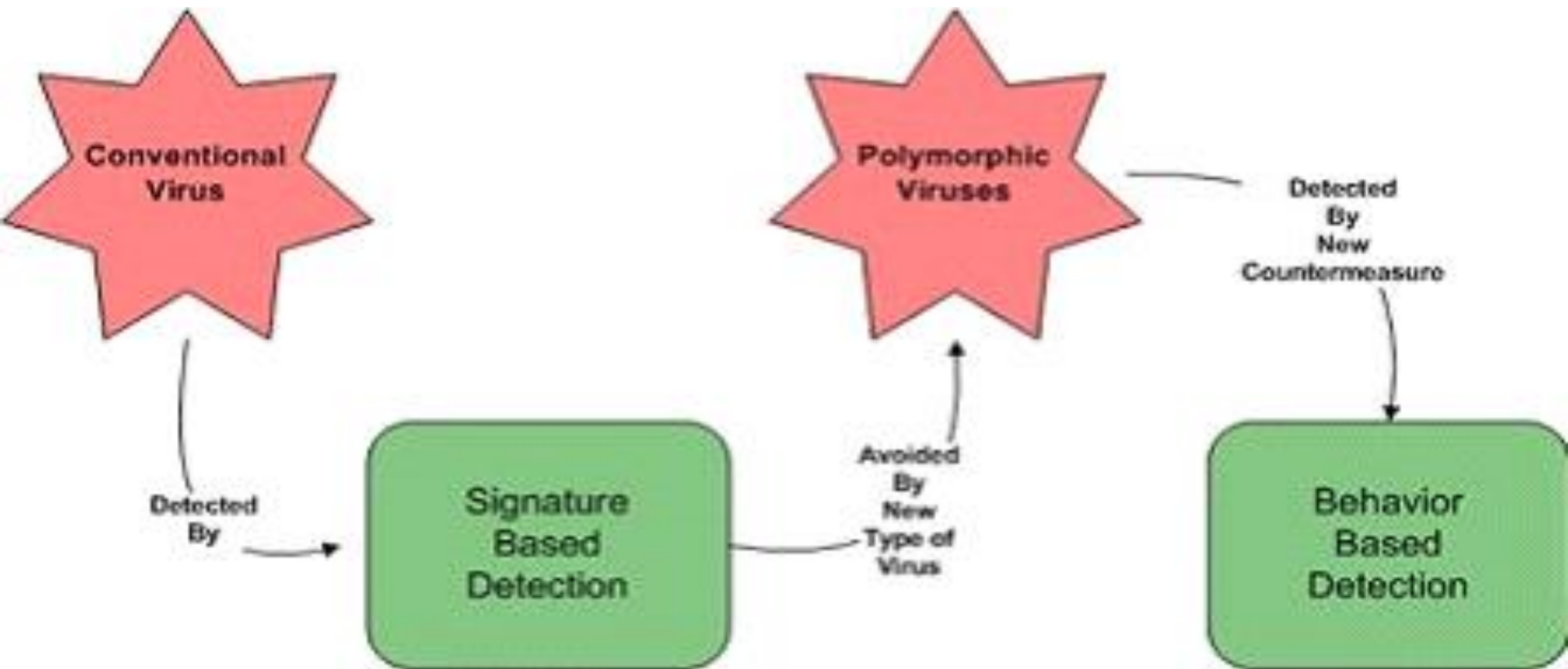
- Malicious software, or malware as it is commonly known, is a relatively dynamic category of threats.
 - The techniques used to destroy data, disrupt services, and steal information have evolved to adapt to changes in security practices and countermeasures.
- ✓ Virus
 - ✓ Worms
 - ✓ Keyloggers
 - ✓ Video frame grabbers
 - ✓ RootKits
 - ✓ Trojan horses.



Malicious codes



Malicious codes



Malicious codes - Virus

Virus

A code segment that replicates by attaching copies of itself to existing executables.

The new copy of the virus is executed when a user executes the new host program.



Virus – Nature & Impact

Virus:

1. Computer viruses are small software programs that are designed to spread from one computer to another and to interfere with computer operation.
2. A virus might corrupt or delete data on the victim's computer, use the victim's e-mail program to spread itself to other computers, or even erase everything on the victim's hard disk.



Virus – Nature & Impact

Virus:

3. Spread by attachments in e-mail messages or instant messaging messages.
4. Viruses can be disguised as attachments of funny images, greeting cards, or audio and video files.
5. Viruses can also spread through downloads on the Internet. They can be hidden in illicit software or other files or programs.



Malicious codes - Worms

Worms

Worms, unlike viruses do not need the host to attach themselves to.

They merely make functional copies of themselves and do this repeatedly till they eat up all the available space on a computer's memory.

Exploit vulnerabilities in operating systems (OSs), network services, and applications to propagate and cause damage.



Malicious codes – Trojan horse

Trojan horses

Appear to be legitimate but in fact contain malware such as keyloggers and spyware.



Discuss: Battle of Troy

Spreading Virus/Worms

Illustration 1

The VBS_LOVELETTER virus (better known as the Love Bug or the ILOVEYOU virus) was reportedly written by a Filipino undergraduate. In May 2000, this deadly virus became the world's most prevalent virus.

Losses incurred during this virus attack were pegged at US \$ 10 billion. VBS_LOVELETTER utilized the addresses in Microsoft Outlook and e-mailed itself to those addresses.

Spreading Virus/Worms

Illustration 1

The e-mail, which was sent out, had "ILOVEYOU" in its subject line. The attachment file was named "LOVE-LETTER-FOR- YOU.TXT.vbs".

People wary of opening e-mail attachments were conquered by the subject line and those who had some knowledge of viruses, did not notice the tiny .vbs extension and believed the file to be a text file.

The message in the e-mail was "kindly check the attached LOVELETTER coming from me".

Spreading Virus/Worms

Illustration 2

Probably the world's most famous worm was the Internet worm let loose on the Internet by Robert Morris sometime in 1988.

The Internet was, then, still in its developing years and this worm, which affected thousands of computers, almost brought its development to a complete halt.

It took a team of experts almost three days to get rid of the worm and in the meantime many of the computers had to be disconnected from the network.

Spreading Virus/Worms

Illustration 3

In 2006, a US citizen was convicted for conspiracy to intentionally cause damage to protected computers and commit computer fraud.

Between 2004 and 2005, he created and operated a malicious software to constantly scan for and infect new computers. It damaged hundreds of US Department of Defence computers in USA, Germany and Italy.

The software compromised computer systems at a Seattle hospital, including patient systems, and damaged more than 1,000 computers in a California school district.

Spreading Virus/Worms

Illustration 4

Logic bombs are event dependent programs.

This implies that these programs are created to do something only when a certain event (known as a trigger event) occurs, e.g. even some viruses may be termed logic bombs because they lie dormant all through the year and become active only on a particular date (like the **Chernobyl virus**).

Spreading Virus/Worms

Law & Punishment:

Under Information Technology (Amendment) Act, 2008, Section 43(c) & 43(e) read with Section 66 is applicable and under Section 268 of Indian Penal Code, 1860 also applicable.

Spreading of Virus offence is cognizable, bailable, compoundable with permission of the court before which the prosecution of such offence is pending and triable by any magistrate.

Modus Operandi

Modus Operandi – Method of Operation

Modus operandi is the behavior necessary for the successful commission of a crime. Douglas & Olshaker (1998:90) define M.O. as "what an offender has to do to accomplish a crime." At a minimum, every M.O. will contain elements that involve the following:

- (1)ensure success of the crime;
- (2)protect identity; and
- (3)effect escape.



Modus Operandi

Modus Operandi – Method of Operation

For example, when a criminal uses duct tape to cover a victim's mouth, this is M.O. because the criminal has realized the victim's screams for help might get him caught.

One cannot always link cases by M.O. because M.O. is dynamic and always changing with experience.

It's learned behavior like any other behavior, and involves things like experience, education, and maturity.

Modus Operandi

1. Classword (the kind of property attacked)
2. Entry (the point of entry)*
3. Means (any implements or tools used)
4. Object (kind of property taken)
5. Time (the time of day or any significance about the day)
6. Style (whether the criminal described themselves as someone else to gain entry)
7. Tale (any disclosure by the criminal about themselves)
8. Pals (whether the crime was committed with confederates)
9. Transport (how the criminal transported himself)
10. Trademark (any unusual behavior in connection with the crime)



Misuse of Public web application

Abuse of Functionality

Abuse of Functionality is an attack technique that uses a web site's own features and functionality to attack itself or others. Abuse of Functionality can be described as the abuse of an application's intended functionality to perform an undesirable outcome.

These attacks have varied results such as consuming resources, circumventing access controls, or leaking information. The potential and level of abuse will vary from web site to web site and application to application.

Abuse of functionality attacks are often a combination of other attack types and/or utilize other attack vectors.

Misuse of Public web application

Abusing Send-Mail Functions

Web Applications that send mail must be careful to not allow the user complete control over message headers and content.

If an attacker can control the From, To, Subject, and Body of a message and there are no anti-automation controls in place email functions can be turned into spam-relay vehicles.

Misuse of Public web application

FormMail

The PERL-based web application "FormMail" was normally used to transmit user-supplied form data to a preprogrammed e-mail address.

The script offered an easy to use solution for web site's to gather feedback. For this reason, the FormMail script was one of the most popular CGI programs on-line. Unfortunately, this same high degree of utility and ease of use was abused by remote attackers to send e- mail to any remote recipient.

In short, this web application was transformed into a spam-relay engine with a single browser web request.

Misuse of Public web application

An attacker merely has to craft an URL that supplied the desired e-mail parameters and perform an HTTP GET to the CGI, such as:

```
http://example/cgi-bin/FormMail.pl?  
recipient=email@victim.example&message=you%20got%20spam
```

An email would be dutifully generated, with the web server acting as the sender, allowing the attacker to be fully proxied by the web-application. Since no security mechanisms existed for this version of the script, the only viable defensive measure was to rewrite the script with a hard-coded e-mail address. Barring that, site operators were forced to remove or replace the web application entirely.

Misuse of Public web application

Abusing Password Recovery Flows

Password recovery flows can often be abused to leak data about accounts that would otherwise be secret. Although usernames on many websites are public knowledge, many sites such as online banks do not reveal a username except to the owner of that account.

Some password recovery flows perform the following steps:

- Ask user for username/email
- Message the user that a mail has been sent to their account
- Send user a link allowing them to change their password

Misuse of Public web application

Abusing Password Recovery Flows

In these types of recovery flows there can be information leakage in step-2 by confirming that the user entered a valid email address and/or account name.

This can be avoided by having generic messaging on this flow or requiring more specific information about the account before sending a reset email.

Misuse of Public web application

Unauthorized Proxy Requests

Some services such as Google Translate can be abused to act as open proxy servers.

Google Translate request functionality allows it to be used as an open proxy server and anonymizer.

This google issue was first described by Sergey Gordeychik and 3APA3A in 2004.

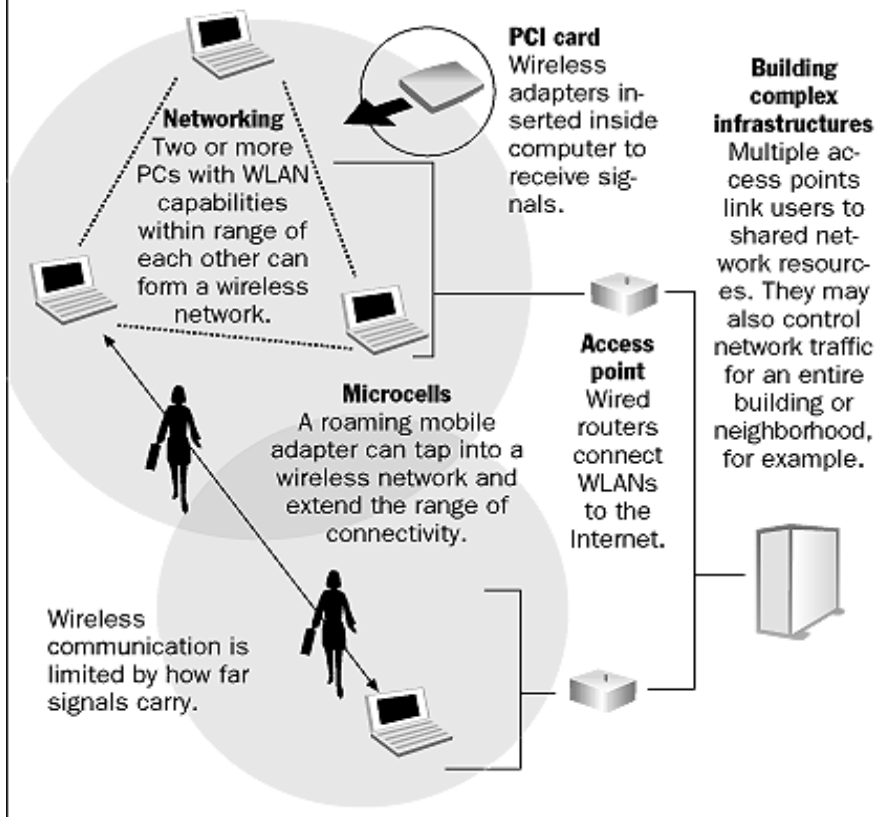
Wireless Network

- A **wireless network** is a computer network that uses wireless data connections between network nodes.
- Wireless networking is a method by which homes, telecommunications networks and business installations avoid the costly process of introducing cables into a building, or as a connection between various equipment locations, admin telecommunications networks are generally implemented and administered using radio communication.
- This implementation takes place at the physical level (layer) of the OSI model network structure.

Wireless Network

How wireless networking works

Wireless communication involves the transmission and reception of information via laser/infrared, microwave or radio signals. An example of how a wireless local area network (WLAN) works:



Source: "HowStuffWorks," "Wireless Networking" by Winn Hong

The Honolulu Advertiser

Wireless Network

- Examples of wireless networks include cell phone networks, wireless local area networks (WLANs), wireless sensor networks, satellite communication networks, and terrestrial microwave networks.

Abuse of Wireless Network

- Stealing wireless network facilities and using it for their personal use
- Uploading/Downloading of illegal files or any other copyrighted materials (books, music, movies, etc.)
- Involving in criminal activities (e.g., sending threatening emails, leaking information, spreading malicious codes, communicating with terrorists, etc.) or hacking, denial of service, capturing network data from other users.

Copyright

- **Copyright** is a legal right created by the law of a country that grants the creator of an original work exclusive rights for its use and distribution. This is usually only for a limited time.
- **Software copyright** is the extension of copyright law to machine-readable software. Software copyright is used by proprietary software companies to prevent the unauthorized copying of their software.



Copyright

- Free and open source licenses also rely on **copyright** law to enforce their terms.
- For instance, copyleft licenses impose a duty on licensees to share their modifications to the copylefted work with the user or copy owner under some circumstances.
- No such duty would apply had the software in question been in the public domain.
- Copyleft is a type of copyright license that allows redistributing the work (with or without changes) on condition that recipients are also granted these rights.

What can be copyrighted?

Work:

A work must meet minimal standards of originality in order to qualify for copyright, and the copyright expires after a set period of time (some jurisdictions may allow this to be extended).

Different countries impose different tests, although generally the requirements are low; in general there has to be some '**skill, labour, and judgment**' that has gone into it.

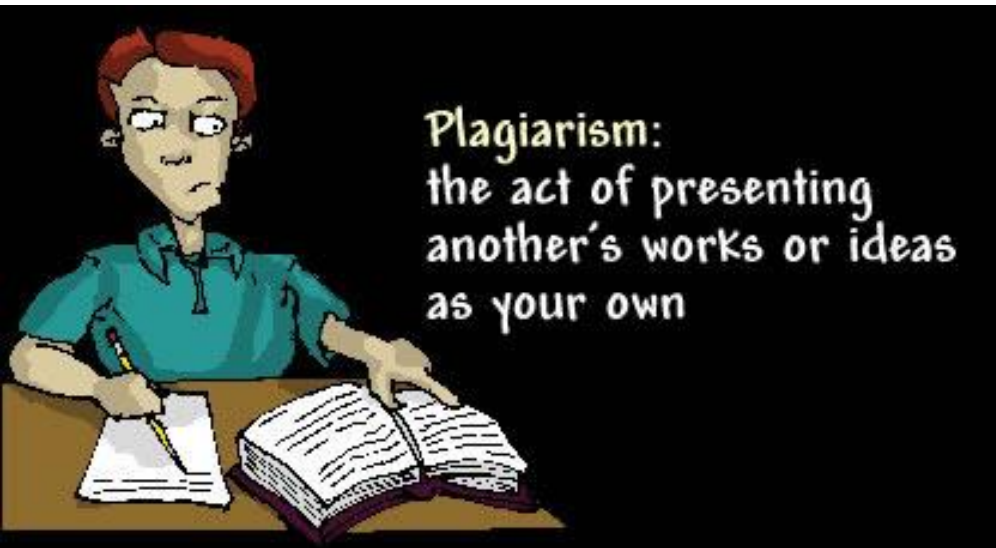
Copyright infringement

Copyright infringement is the use of works protected by copyright law without permission, infringing certain exclusive rights granted to the copyright holder, such as the right to reproduce, distribute, display or perform the protected work, or to make derivative works.

The copyright holder is typically the work's creator, or a publisher or other business to whom copyright has been assigned.



Plagiarism



Software industry frauds

➤ Software piracy

The unauthorized copying of software. Most retail programs are licensed for use at just one computer site or for use by only one user at any time.

By buying the software, you become a *licensed user* rather than an owner.

You are allowed to make copies of the program for backup purposes, but it is against the law to give copies to friends and colleagues.

Software piracy

Software piracy is all but impossible to stop, although software companies are launching more and more lawsuits against major infractors.

Originally, software companies tried to stop software piracy by copy-protecting their software. This strategy failed, however, because it was inconvenient for users and was not 100 percent foolproof.

Most software now requires some sort of registration, which may discourage would-be pirates, but doesn't really stop software piracy.

e.g., Counterfeit software, OEM unbundling, Softlifting, Hard disk loading, Corporate software piracy, Internet software piracy, etc.

Software code theft

Illustration 1

- A software professional from Bangalore (India) was booked for stealing the source code of a product being developed by his employers.
- He started his own company and allegedly used the stolen source code to launch a new software product.



Software code theft

Illustration 2

- In 2003, a computer user in China obtained the source code of a popular game - Lineage from an unprotected website.
- This proprietary code was then sold to several people in 2004. One of those people set up a website, www.l2extreme.com, to offer the "Lineage" game at a discount.
- Despite legal warnings from the South Korean company that owned the Lineage source code, the suspect did not shut down the site.

Software code theft

- He rented powerful servers enough to accommodate 4,000 simultaneous gamers - and solicited donations from users to help defray the costs.
- The loss in potential revenues for the South Korean company was estimated at \$750,000 a month. The US FBI arrested the suspect and the website was shut down.

Selling fake computer software

IT and Telecom
Sector Frauds and
Countermeasures



SPEED UP YOUR PC NOW!

Clean up and speed up your PC in seconds...

Windows 7
Detox your Windows 7 (32/64 bit) PC

Windows 8
Detox Windows 8 (32/64 bit) PC

DOWNLOAD NOW



Free Scan

Clean & Repair Windows Errors and Eliminate Crashing & Freezing!

SCAN NOW!

FAKE

What is a DLL Error?

It is a missing or corrupted file essential to run Windows Programs.
A **Corrupted DLL** File may cause Damage to your PC!

Recommended Software: ★★★★★

**CLICK HERE TO DOWNLOAD
DLL FILES**

Selling fake computer software

Fake software – Anti-virus



It may not:

- a) work properly.
- b) function effectively.

It may:

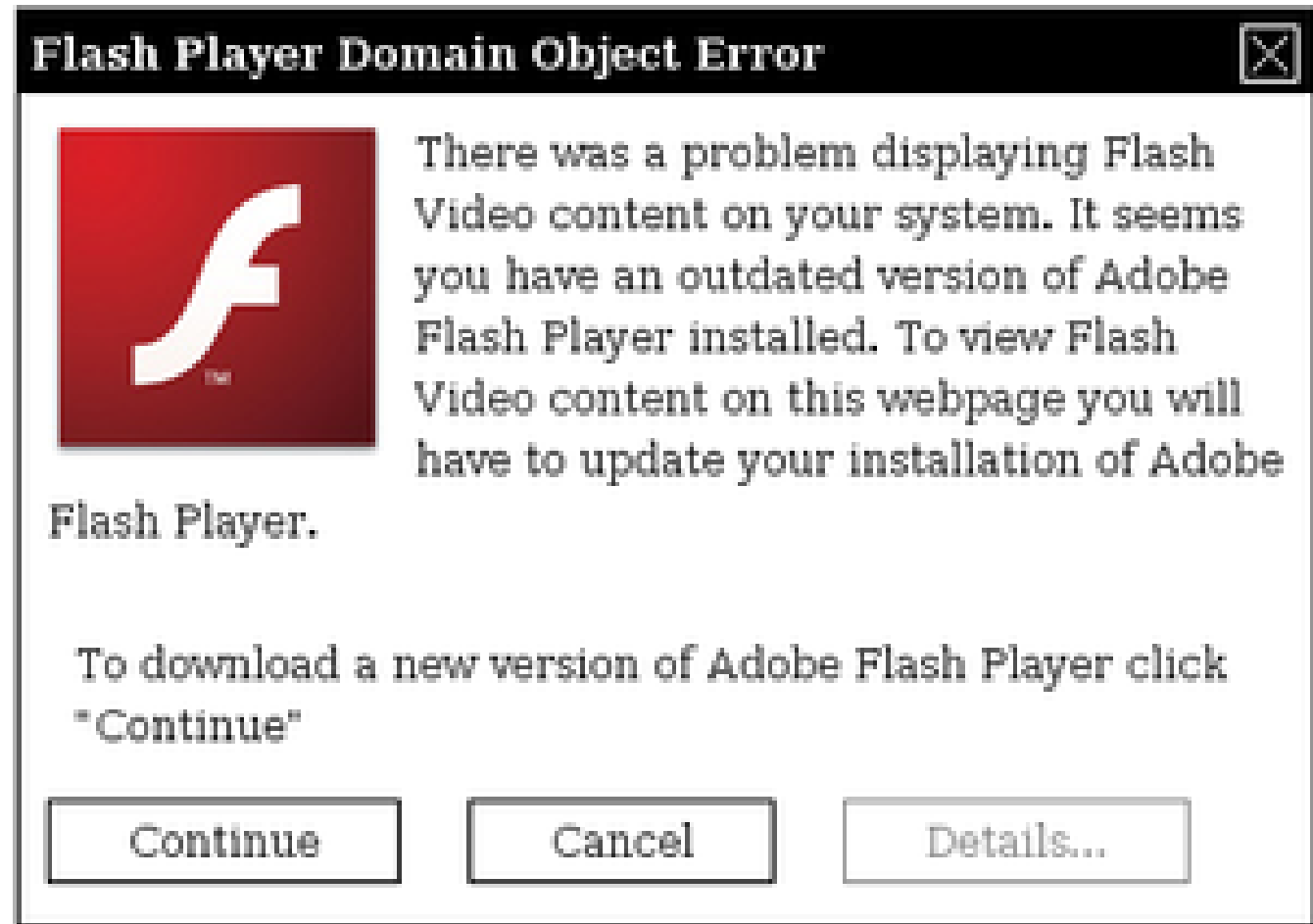
- a) work falsely.

Fake alerts

Fake alerts:
Pop ups

It may be:

Malware
DNS Poisoning
Identity theft



Malwares wrapped

Key loggers



Malware – Trojan

Illustration:

- A young lady reporter was working on an article about online relationships. The article focused on how people can easily find friendship and even love on the Internet. During the course of her research she made a lot of online friends.
- One of these 'friends' managed to infect her computer with a Trojan. This young lady stayed in a small one bedroom apartment and her computer was located in one corner of her bedroom.
- Unknown to her, the Trojan would activate her web camera and microphone even when the Internet was switched off. A year later she realized that hundreds of her pictures were posted on pornographic sites around the world!

Defective software

- Inadequate modules.
- Improper testing.



FAIL
**QUALITY
CONTROL**

After sales shocks

- Frequent paid updates
- Version announced as obsolete – Followed by major release
- Application software support withdrawal



Fake promises

- Warranty terms – Compatibility issues (e.g., OS limitations)
- Warranty period
- Upgrades
- Fixes (Bugs)
- Performance
- Limited installations



Backdoors

- A **backdoor** is a method, often secret, of bypassing normal authentication in a product, computer system, cryptosystem or algorithm etc.
- Backdoors are often used for securing unauthorized remote access to a computer, or obtaining access to plaintext in cryptographic systems.
- A backdoor may take the form of a hidden part of a program, a separate program, or may be a hardware feature.

Backdoors

- Although normally surreptitiously installed, in some cases backdoors are deliberate and widely known, and may have somewhat legitimate uses such as the manufacturer having a way to deal with users losing passwords.
- Default passwords can function as backdoors if they are not changed by the user. Some debugging features can also act as backdoors if they are not removed in the release version.

Backdoors

- In 1993 the United States government attempted to deploy an encryption system, the Clipper chip, with an explicit backdoor for law enforcement and national security access.
- The chip was unsuccessful internationally and in business.

Backdoors



Windows-based
backdoor
Trojan horse

Q & A



**E.R. Ramesh, M.C.A., M.Sc., M.B.A.,
98410 59353, 98403 50547
rameshvani@gmail.com**